PASSIVE RECONNAISSANCE

TryHackMe Learning & Practical Report

Prepared by: Sofia

Focus: Web Application Security / WAPT Foundations

Platform: TryHackMe

Room: Passive Reconnaissance

IqraSec Academy - WAPT Internship - Phase 1

1. Executive Summary

This room taught me how to collect information about a target without touching it directly. I used WHOIS to read domain registration data, nslookup/dig to read DNS records, DNSDumpster to see subdomains and hosting, and Shodan to see internet-facing services.

2. Lab Information

Platform	TryHackMe
Room / Lab	Passive Reconnaissance
Primary Domain	Web Application Security
Purpose	Foundational WAPT practice
Completion	Completed - all room tasks finished
Link	https://tryhackme.com/room/passiverecon

3. Learning Objectives

- Understand the difference between passive and active reconnaissance.
- Use WHOIS to find registrar, dates and name servers.
- Query DNS records with nslookup and dig.
- Use DNSDumpster to map subdomains and hosting.
- Use Shodan to see exposed services and common ports.

4. Passive vs Active Recon

Passive recon uses public sources only, so the target does not see any traffic from me. Active recon talks to the target directly and can be logged. The first step of any test is usually passive.

5. WHOIS

I ran whois tryhackme.com on the Kali AttackBox. It showed the registrar (Namecheap), the creation date (2018-07-05), the abuse contact and the name servers, which belong to Cloudflare. Privacy protection hides the registrant details, which is good defence.

6. nslookup and dig

I used dig thmlabs.com TXT to read the TXT records. The answer section contained a flag, which shows that TXT records are public and can hold information that should not be there.

7. DNSDumpster and Shodan

DNSDumpster listed hosts, IP addresses, hosting providers and the services/banners for tryhackme.com; the banner with the highest count was Cloudflare. In Shodan I searched the domain and looked at countries, organisations and the most common ports of Apache and nginx servers.

8. Evidence

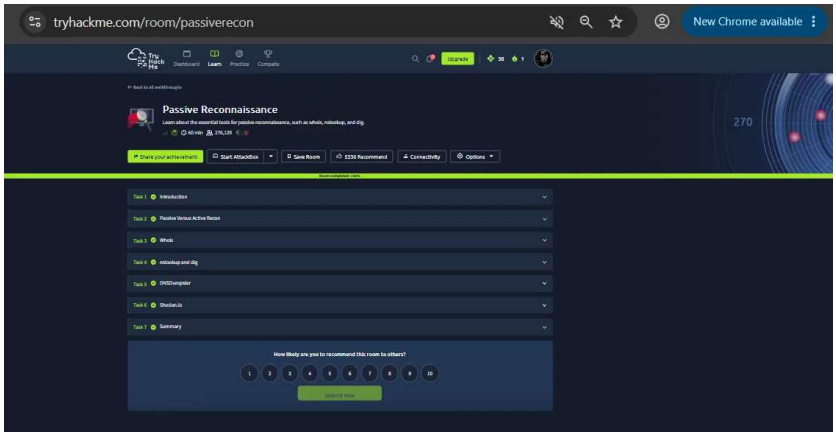


Fig 1 - Room overview.



Fig 2 - WHOIS questions answered (registration date, registrar, name servers).

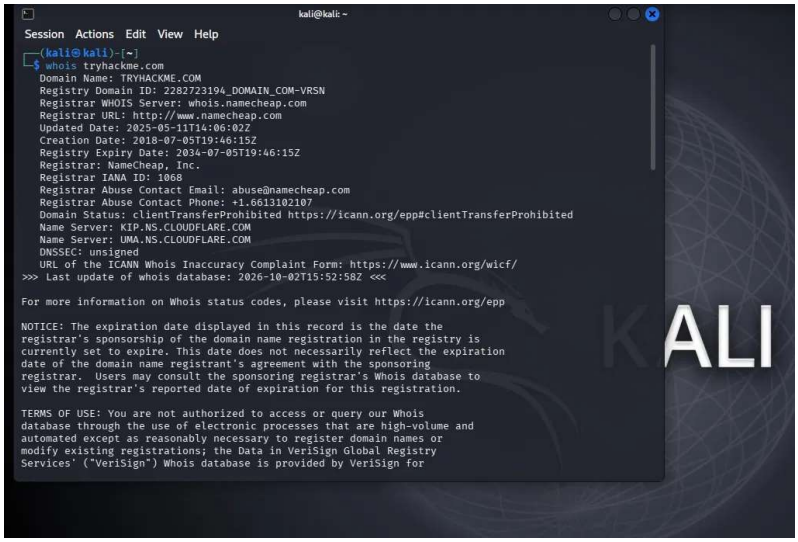


Fig 3 - whois tryhackme.com on the AttackBox.

```
┌──(kali㉿kali)-[~]
└─$ dig thmlabs.com txt

; <<>> DiG 9.20.26-1-Debian <<>> thmlabs.com txt
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 41230
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 512
;; QUESTION SECTION:
;thmlabs.com.                   IN      TXT

;; ANSWER SECTION:
thmlabs.com.            5       IN      TXT     "THM{a5b83929888ed36acb0272971e438d78}"

;; Query time: 2068 msec
;; SERVER: 192.168.152.2#53(192.168.152.2) (UDP)
;; WHEN: Fri Oct 02 11:56:34 EDT 2026
;; MSG SIZE  rcvd: 90
```

Fig 4 - dig thmlabs.com TXT.

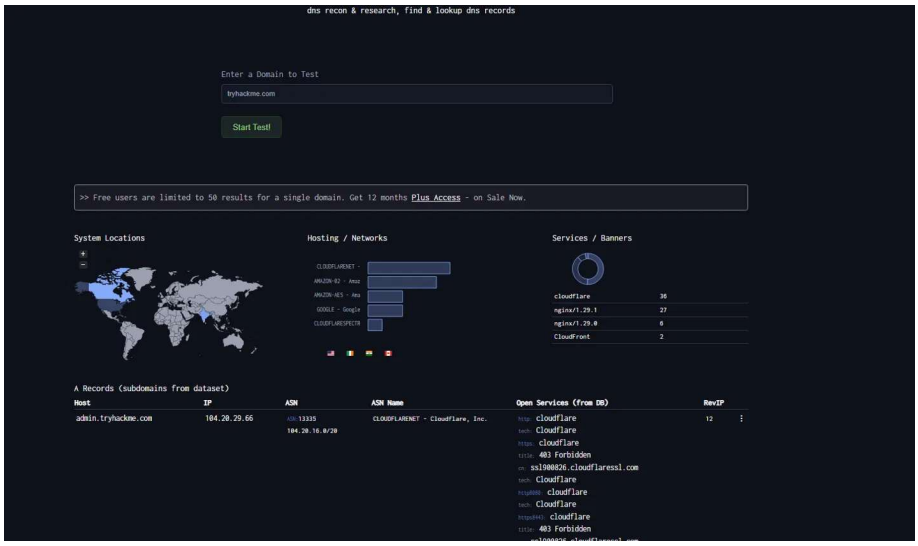


Fig 5 - DNSDumpster result for tryhackme.com.

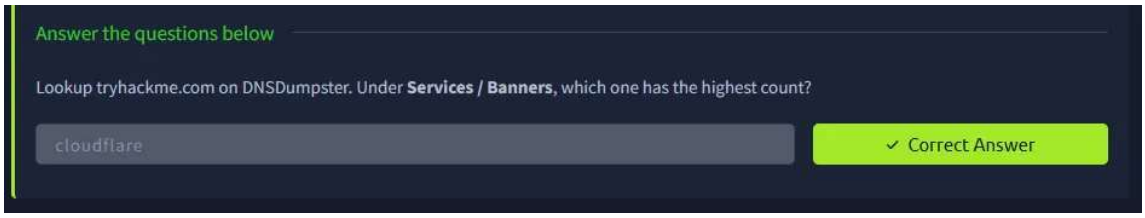


Fig 6 - Services/banners question answered.

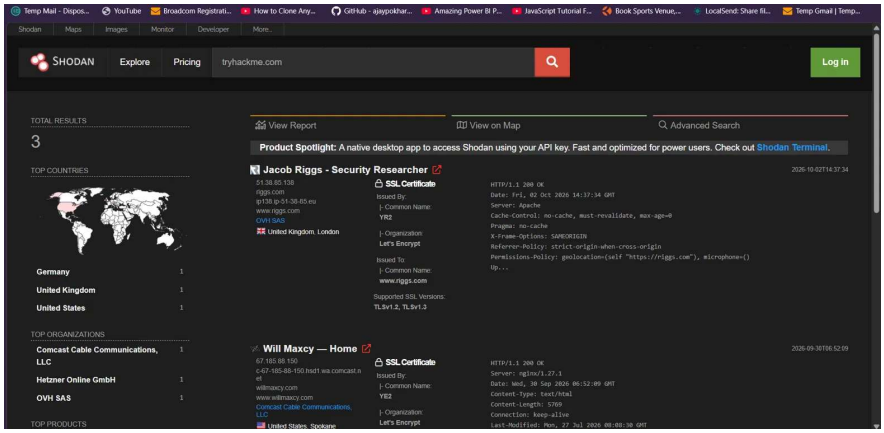


Fig 7 - Shodan search.

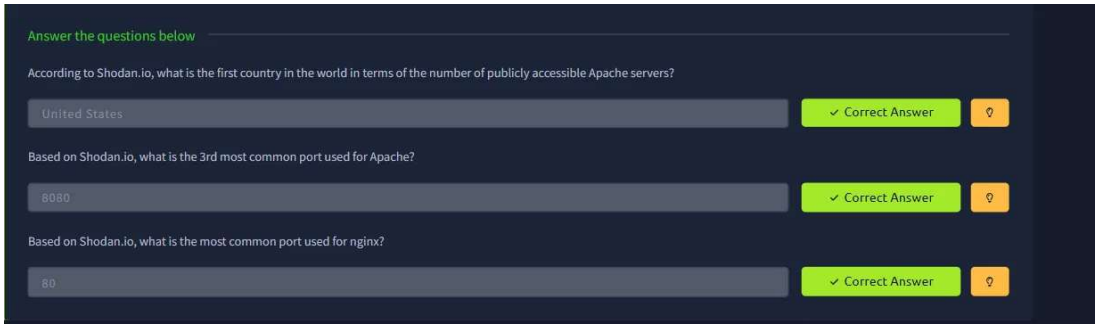


Fig 8 - Shodan questions answered.

9. Key Security Takeaways

- A lot of information about a target is public: owner, name servers, hosting, subdomains.
- DNS TXT records and old data can leak sensitive values.
- Domain privacy protection and monitoring DNS changes are simple defences.
- Passive recon is safe for me because it does not touch the target.

10. Skills Practiced

Area	**Practical understanding gained**
WHOIS	Reading registrar, dates and name servers
DNS	nslookup and dig for TXT records
Subdomains	DNSDumpster
Exposed services	Shodan search and filters

11. What I Would Explore Next

I will combine this with active recon and content discovery to map the full attack surface of a target.

12. Conclusion

Passive reconnaissance showed me that I can learn a lot about a company before sending a single packet. I will always begin a test with these tools.

Completion status: Completed - all room tasks finished.

13. References

TryHackMe: https://tryhackme.com/room/passiverecon